

41

CPG와 대규모 언어모델을 결합한 Java 소스코드 보안 취약점 탐지 시스템

소속 정보컴퓨터공학부

분과 D

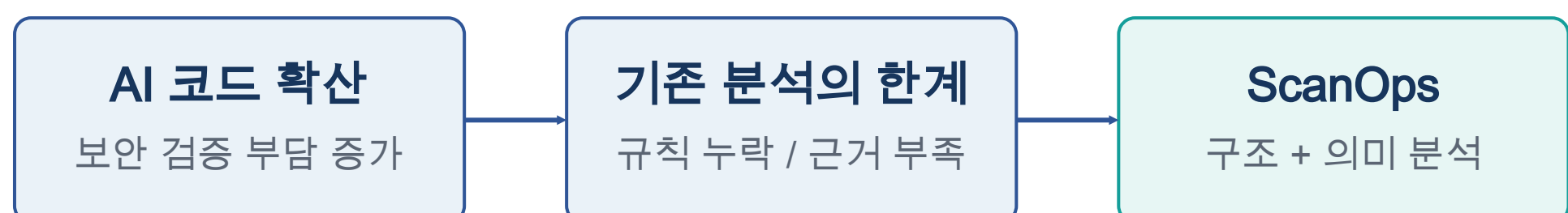
팀명 ScanOps

참여학생 김세한, 이경윤, 전해은

지도교수 손준영

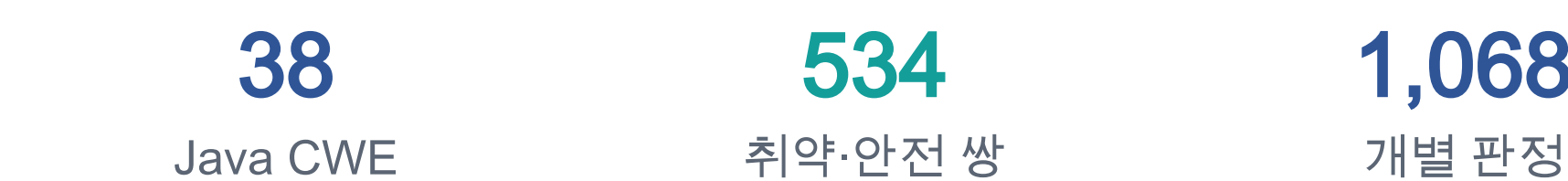
과제 개요

연구 배경과 목표



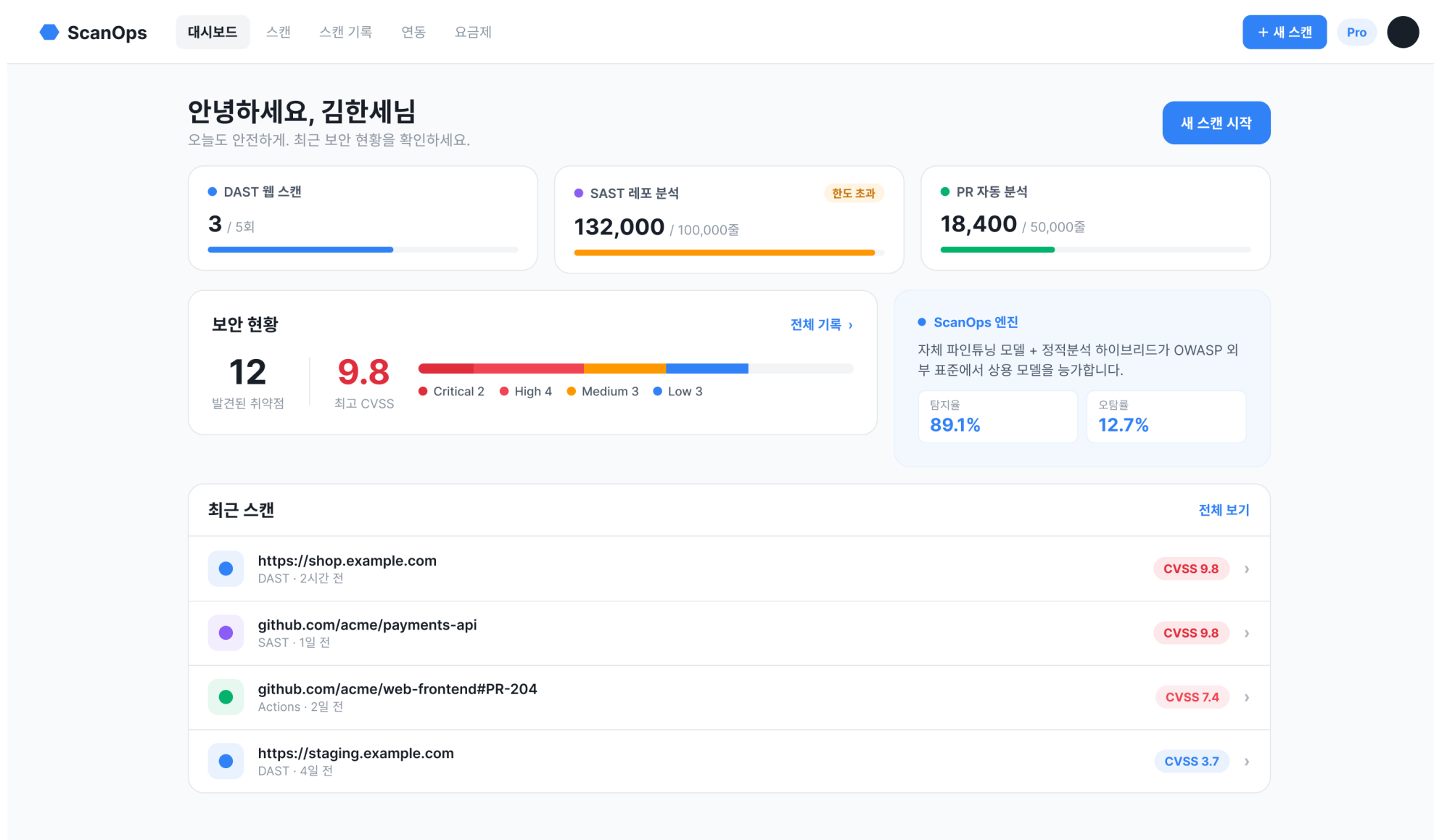
Joern CPG는 취약 경로를 계산하고, Qwen은 외부 API 역할과 코드의 의미를 보완한다. 검증 gate가 수용 범위를 제한한다.

동일 조건의 벤치마크 평가



NIST Juliet Java 1.3 / 중복 제거와 개발·평가 분리
고정 CPG, CPG+Qwen 규칙, Qwen source-only, CodeQL 비교

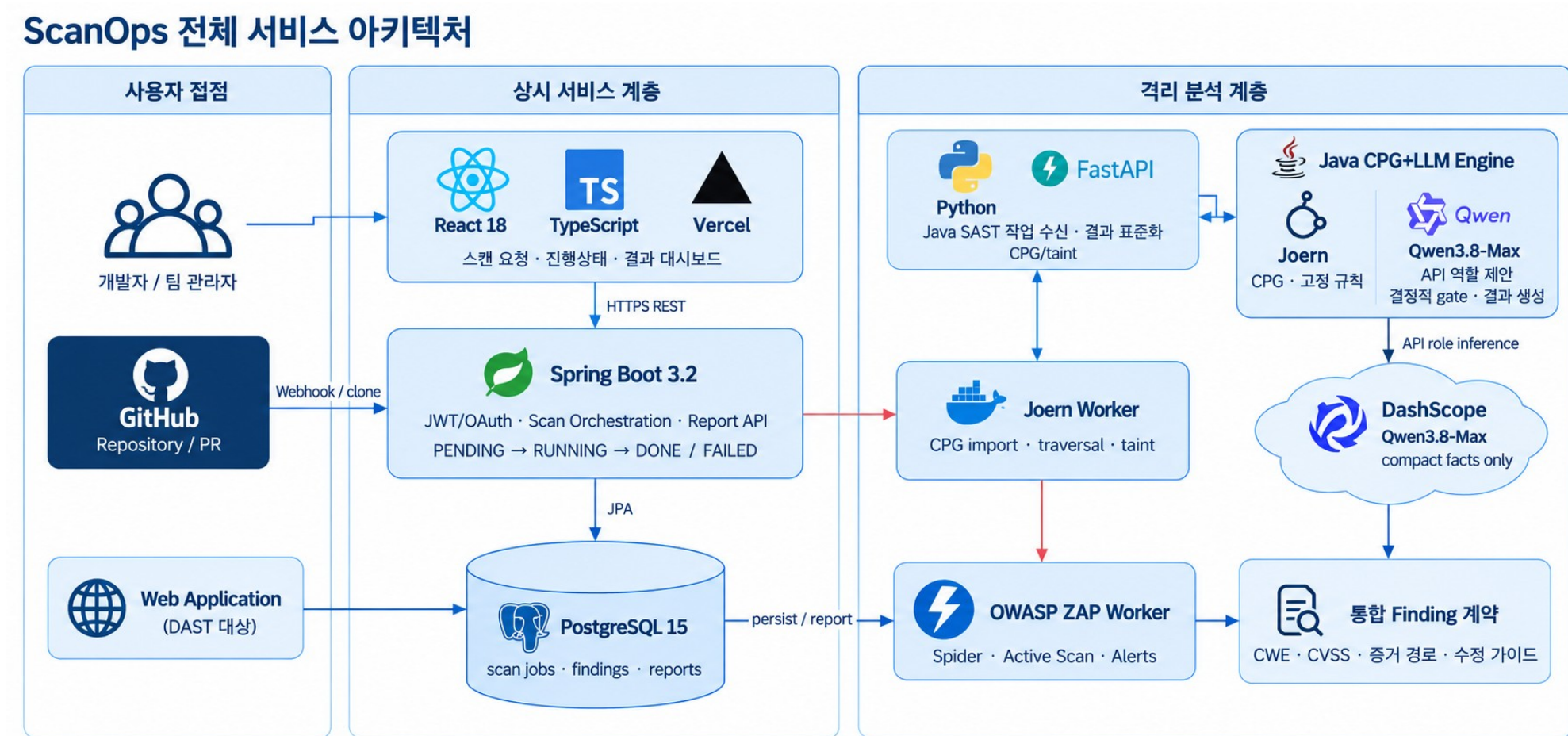
서비스 대시보드



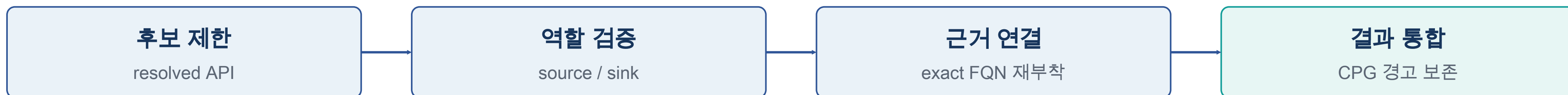
Figma 설계 화면 · 화면 속 예시 수치는 연구 성능 지표와 별개

핵심 기술 및 구현

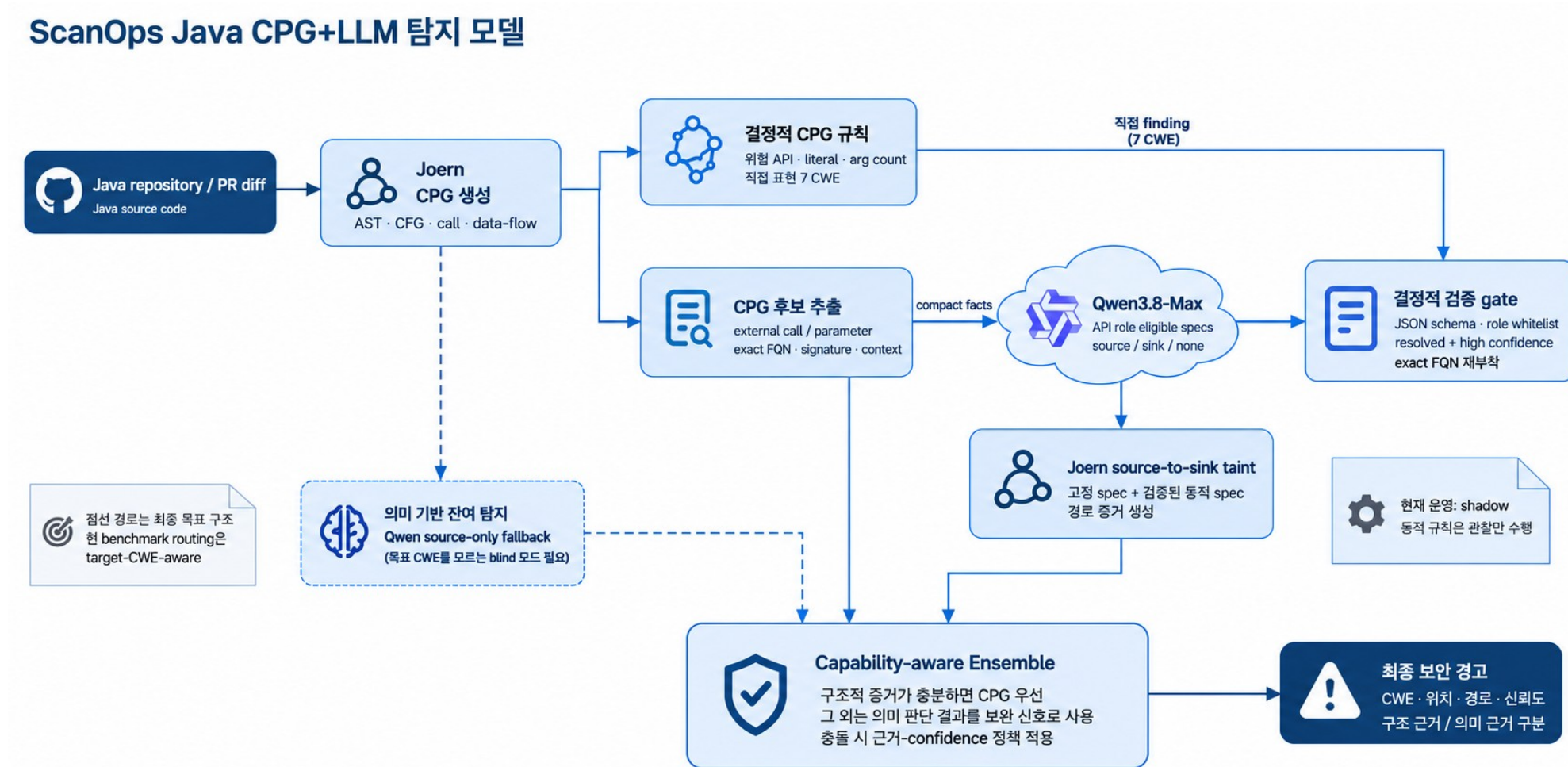
전체 서비스 아키텍처



Java 요청은 별도 분석 EC2로 분리한다.
FastAPI와 Joern worker가 분석하고 백엔드·DB로 결과를 전달한다.



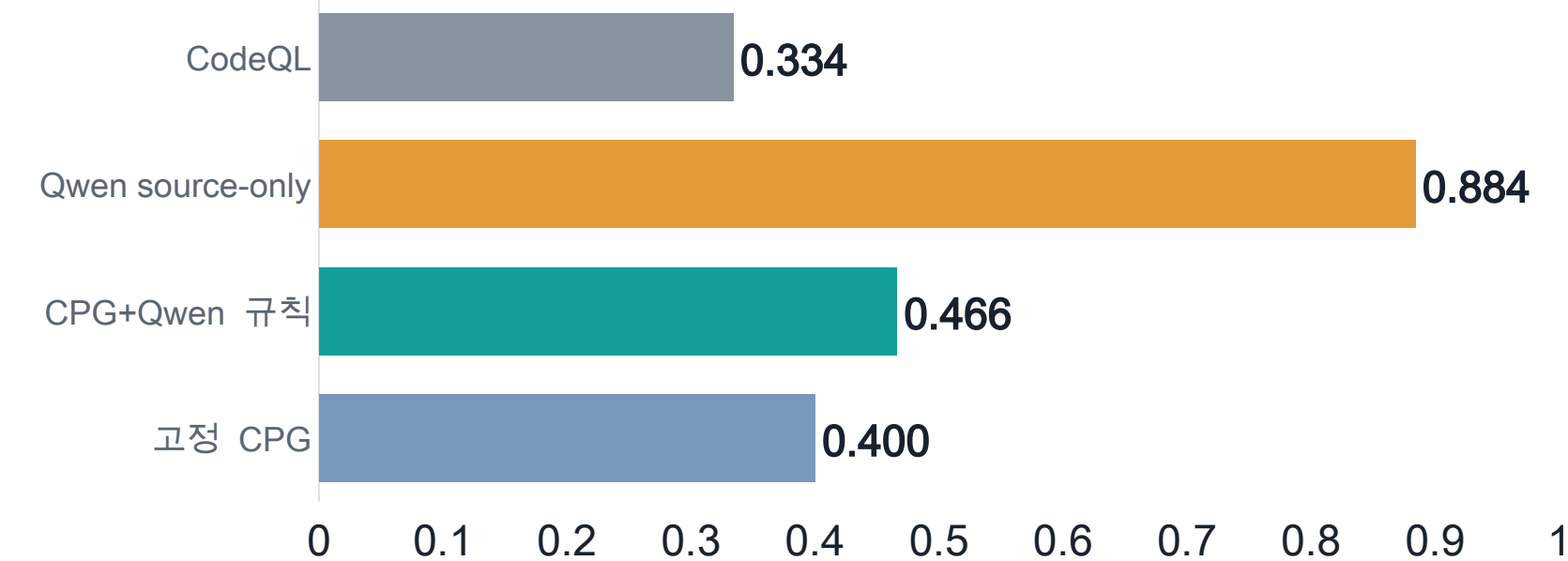
Java CPG+LLM 탐지 모델



API 역할 제안은 결정적 gate로 검증한다.
동적 API 규칙은 운영에서 shadow이며 접선은 목표 구조이다.

실험 결과 및 결론

전체 38 CWE F1



Qwen source-only 0.884는 목표 CWE를 제공한 target-CWE-aware closed-set 실험 결과이다.

능력별 결과

직접 7 CWE
F1 1.000 FPR 0

Taint 14 CWE · Recall

고정 CPG 20.0% → Qwen 규칙 보강 34.8%

F1 0.286 → 0.435 / FPR 20.0% → 25.2%

결론과 한계

CPG는 직접 규칙 영역에서 안정적이었다.

Qwen 규칙은 탐지율과 함께 오탐도 늘렸다.

서비스 연동을 확인했으며, 실제 CVE 일반화는 후속 독립 평가가 필요하다.

오프라인 router 후보 F1 0.901은 목표 CWE를 사용한 연구 결과이며 실제 배포 알고리즘이 아니다.